

Lab: Password Reset Broken Logic

Summary

A broken password reset workflow allowed an attacker to change another user's password by manipulating the password reset process. The application failed to properly bind the password reset request to the legitimate account owner, resulting in unauthorized account takeover.

Vulnerability

Broken Authentication / Password Reset Logic

Severity

High

Description

The password reset functionality contained a logical flaw where the server trusted user-controlled input during the password reset flow instead of securely validating ownership of the reset request.

By modifying the request parameters, it was possible to reset the password of another user without possessing a valid reset token for that account.

This issue demonstrates how broken business logic in authentication workflows can lead to complete account compromise.

Steps to Reproduce

1. Initiate the password reset process for a legitimate account.
2. Intercept the password reset request using an intercepting proxy.
3. Modify the user identifier (such as username or email) to target another account.
4. Forward the modified request.
5. Complete the password reset process.
6. Observe that the target account's password is successfully changed.

Impact

- Unauthorized password reset
- Account Takeover (ATO)
- Complete loss of account integrity
- Unauthorized access to sensitive user data

Root Cause

The application failed to securely associate the password reset operation with the intended account. Instead, it relied on client-controlled parameters without performing proper server-side authorization checks.

Recommended Fix

- Bind password reset requests to cryptographically secure, single-use reset tokens.
- Never trust client-controlled identifiers during the reset flow.
- Validate ownership of the reset request on the server side.
- Expire reset tokens after use or after a short time window.
- Log and monitor password reset attempts for suspicious activity.

References

- OWASP Top 10 – Broken Access Control
- OWASP Authentication Cheat Sheet
- OWASP Forgot Password Cheat Sheet

Disclaimer: This report is based on a PortSwigger Web Security Academy lab completed for educational purposes. No real-world systems were targeted.

The screenshot displays a web application security tool interface. On the left, the 'Request' tab is active, showing a POST request to `/forgot-password?temp-forgot-password-token=x`. The request body contains a form with fields for `username` (value: carlos), `new-password-1` (value: 12345), and `new-password-2` (value: 12345). On the right, the 'Response' tab is active, showing an `HTTP/2 302 Found` status with a `Location: /` header. Red arrows point from the request body fields to the response, indicating that the server is redirecting based on client-controlled data. Below the tool, a screenshot of the application's 'My Account' page is shown, displaying the user's name 'carlos' and email 'carlos@carlos-montoya.net'. A form with an 'Email' input field and an 'Update email' button is also visible.